Sky LIS — Validation Report

Full validation of the application as released: the automated test suites, every Release-1 page and function of the Super Admin and client portals, the public pages, and the backend cycle from the screen to the PostgreSQL database.

DOCUMENT
LIS-VR-001 · v1.0

VALIDATION DATE
2026-10-11

RELEASE UNDER TEST
v0.3.8 (commit `3a83e9c`), github.com/arfaawadnt/Sky-LIS

ENVIRONMENT
WIN-9S2KO4FA64L: validation stack (API 127.0.0.1:5102, SPA :4300) and the installed site https://192.168.80.38:5443, one database `lis` (PostgreSQL 17, :5433)

DETAILED RESULTS
`docs/validation/2026-10-11/*.md`, script `tests/validation/backend-cycle.mjs`

Verdict: functionally and data-wise validated — two session defects must be fixed before shared-workstation use

Every Release-1 business workflow of both portals works end to end, every business rule tested is enforced by the server, and every save checked reached the database with the right values, tenant, links, audit entries and processed outbox events. No data loss or data corruption was found in the backend, and tenant isolation held at the API and at the database row level.

The defects are in the browser application. Two are severity 1 and both concern **two users sharing one browser**: after a sign-out and sign-in, some pages keep the previous user's data (A-01), and a forgotten tab can continue as the user who signed in last (C-01). Five severity-2 defects lose user input or mis-report a successful save. The recommendation is to fix the S1 and S2 groups (section 6), re-test them, and then open user acceptance with the personas.

1,589
automated tests passed, 0 failed (backend 1,212 · frontend 377)

469
manual test cases on the two portals; 457 executed, **403 passed** (88 %)

36 / 36
backend-cycle steps passed with 320 database assertions; 5 / 5 on the installed site

56
database verifications after UI saves, all matching what the screen saved

49
findings: 2 × S1 · 5 × S2 · 21 × S3 · 21 × S4, in 14 fix groups

1. Scope and method

- **Automated layer.** The full solution build and the five backend suites (domain, architecture gates, application, integration on a real PostgreSQL, functional through the real API and database), the frontend lint with module boundaries, the frontend unit tests and the production build.
- **Manual layer, page by page.** Four testers covered every Release-1 menu entry of both portals (26 client, 33 Super Admin) and the public pages: every list (search, filters, sort, paging, export), every editor (create, edit, validation messages, activate and deactivate), every row action and dialog, the keyboard shortcuts, the permissions of each persona, and the Arabic right-to-left view of each page. Expected results came from the business SRS (LIS-SRS-001), the module intakes and the UAT scripts (LIS-UAT-001 v0.4).
- **Backend cycle.** After every save on a screen the tester queried the database read-only: the row in the right table with exactly the entered values and tenant, the child rows, the audit trail and field changes, and the processing of the transaction's outbox events. A fifth tester built a repeatable script that drives the API directly through a complete laboratory cycle and asserts the database after each request, including the negative and isolation checks.
- **Release-1 scope only.** Release-2 pages hidden by the release switch were not tested. Nothing was changed in the application during the validation; every defect is recorded with its suspected cause instead.

2. Results by layer

2.1 Automated suites

SUITE	WHAT IT PROVES	PASSED	FAILED
Backend build (`Platform.sln` , warnings as errors)	the solution compiles cleanly under the analyzers	0 warnings	0 errors
Domain unit tests	aggregates, state transitions, invariants, segregation of duties	714	0
Architecture tests	layer rules, request policies, migrations, release versioning, deployment package gates	99	0
Application unit tests	command and query handlers, security primitives, configuration guards	213	0
Integration tests (real PostgreSQL)	persistence, row-level security, audit chain, outbox, read ports	109	0
Functional tests (real API + database)	sign-in, provisioning, registration, billing, results flows over HTTP	77	0
Frontend lint and module boundaries	code rules and feature isolation	clean	0
Frontend unit tests (106 files)	facades, pages, interceptors, guards, shared kit	377	0

SUITE	WHAT IT PROVES	PASSED	FAILED
Frontend production build	the shipped bundle builds; one budget warning: the landing page stylesheet is 29 bytes over its 4 kB budget	built	0
Total automated tests		**1,589**	**0**

2.2 Manual validation of the portals

AREA	PAGES COVERED	CASES	EXECUTED	PASSED	FAILED	BLOCKED	NOT TESTED	DEFECTS
A · Client operations (demo laboratory)	dashboard, registration and edit, search registrations and all row actions, job order, price query, patients, worklist, results by accession, payments, refunds, treasury access, treasuries, profile, session	133	128	118	10	1	4	1 S1 · 7 S3 · 7 S4
B · Client set-up from an empty laboratory	branches, roles & privileges, users, clinical groups, sample types, units, tests (numeric, list, formula, text), services (single, profile, package), sequence, preparations, comments, doctors, microbiology lists, payers and tiers, base price lists, treasuries and access; proof registration and result entry with the new set-up	197	196	176	20	0	1	2 S2 · 4 S3 · 8 S4

AREA	PAGES COVERED	CASES	EXECUTED	PASSED	FAILED	BLOCKED	NOT TESTED	DEFECTS
C · Super Admin portal and public pages	home, dashboard, roles, admin users, clients and provisioning, subscriptions and wallets, sessions, audit log and chain, 18 master-data registers, countries, governorates, platform parameters, notification templates, profile; public site, subscription wizard, sign-in, recovery; portal isolation	139	133	109	24	3	3	1 S1 · 3 S2 · 9 S3 · 6 S4
Total		**469**	**457**	**403**	**54**	**4**	**8**	**2 S1 · 5 S2 · 20 S3 · 21 S4**

A failed case is a case whose observed behaviour differs from the specification; the 54 failed cases map to 48 defects because several cases share one cause (for example the missing export on five set-up pages).

2.3 Backend cycle (API to database)

RUN	CONTENT	STEPS	DATABASE ASSERTIONS	VERDICT
Full cycle, validation API	provision a new client; users, role with reduced rights; catalogue (group, sample type, unit, numeric test with range and panic limits, list test, services); price list, cash and credit payers; treasury and access with segregation of duties; patient; visit of 250 EGP with payments of 100 and 150; result entry with panic flag, verify-before-review refused when the setting is on, review, verify, amend; cancellation and refund; tenant setting	36 / 36	320	pass
Negative and integrity checks	validation 400 with problem details; duplicates refused (`CAT-102`) and the unique index under concurrency (`UNIQUE-409`); stale row version (`CONCURRENCY-409`); missing permission (403 `AUTHZ-001`); another laboratory reading the records (404, nothing leaks); database row-level-security probe (0 rows under another tenant); audit entries and hash chain verified; no password, hash or security stamp in audit or outbox payloads	included	included	pass

RUN	CONTENT	STEPS	DATABASE ASSERTIONS	VERDICT
Deployed path, installed site	https://192.168.80.38:5443 through IIS and the service: sign-in, list, create, database check	5 / 5	—	pass

3. Data persistence evidence

Every save performed on a screen was followed by a read-only query of the database as the owner role. All 56 verifications matched what the screen saved.

AREA	VERIFICATIONS	WHAT WAS CONFIRMED	OUTBOX AND AUDIT
A · Client operations	13	visits with lines, tubes and samples; results and their log; payments, voids and refunds with the visit balance; treasury access requests and decisions; patient files and uploaded documents	every outbox event processed, none dead-lettered; audit events and field changes written
B · Client set-up	20	branches, roles with permissions, special and result rights, users with branch assignments; tests with range bands, list values, formula and paragraphs; services with members; price lines; payers and tiers; treasuries	123 events processed, none dead-lettered; audit trail 128 entries without gaps
C · Super Admin	23	provisioned client (tenant, wallet, branch, administrator, membership, role) and the copy of all 21 master-data tables with remapped references; plans and wallet top-ups; master-data registers; countries, governorates, parameters, templates	957 events processed, none dead-lettered; audit chain verified (59 entries)
D · Backend cycle script	320 assertions	every API write asserted on status, amounts, reference numbers, tenant and foreign keys	events matched to the audit trail; slowest processed in 1.9 s

4. Business rules confirmed

- **Registration and money:** duplicate and gender-restricted services, reserved lines, discount cap and mandatory reason, partial payment, non-cash reference, payment above the remaining balance refused, payment only on a treasury approved for the device, refund limited to the refundable amount, cancellation with reason, verified lines cannot be cancelled.
- **Results:** entry only on received samples, flags and panic values against the age and sex band, formula computation, list and text tests, delta acknowledgement, verify refused with missing values, review-before-verify when enabled, amend only with the special right and a reason, result rights per clinical group and branch.
- **Segregation of duties:** a treasury access requester cannot approve their own request (`SOD-TRS-001`).
- **Organization and security:** live permission change (BR-17), branch selection, must-change password gate, lockout after five failures, lock and unlock, deactivated client refused at sign-in (`CLI-020`), password policy inherited from the platform parameter.
- **Catalogue and pricing:** unique codes (`CAT-0xx`), BR-19 affordances, price list copy with factor, contract tiers (`PRC-0xx`), master-data copy to new clients (BR-25).
- **Isolation:** tenant isolation at the API (404 across laboratories) and in the database (row-level security), client feature routes closed to platform sessions, `/admin` closed to laboratory sessions.

5. Defect register

Severity: S1 security, data loss or a blocked workflow · S2 wrong result, workaround exists · S3 minor functional · S4 cosmetic. Ids are those of the detailed result files (A client operations, B client set-up, C Super Admin and public, D backend cycle).

5.1 Severity 1 and 2

ID	SEV.	FINDING	MODULE	CAUSE	GROUP
`C-01`	S1	A tab whose session ended keeps showing its user but continues as whoever signed in last in the same browser: the shared refresh cookie is used and the request replayed. A stale tab's password change ran as the platform administrator.	Frontend core (auth)	the store adopts the refreshed profile without checking that user and tenant are unchanged (`auth.store.ts` , `auth.interceptor.ts`)	FG-1
`A-01`	S1	After sign-out and sign-in in the same tab, the worklist and results by accession keep the previous user's data and rights; a chemistry-only technician saw haematology values. The server refused the write (read exposure).	Results	route-provided facades survive sign-out; sign-out navigates without reloading	FG-2

ID	SEV.	FINDING	MODULE	CAUSE	GROUP
C-13	S2	The account pages keep the previous session's data: a user without audit rights saw the platform audit log; the platform administrator saw a laboratory's profile.	Account	same as A-01	FG-2
C-02	S2	Roles and admin users treat every successful empty answer (204) as a failure: no confirmation, the reset-password dialog stays open.	Organization	204 resolves to `null` in `organization.api.ts` (also pricing, results, patients, samples, integration)	FG-3
C-05 / B-04	S2	When one save step of the test editor is refused, the typed range bands or list values are lost and the server's reason (`CAT-053/054/058/070`) is never shown.	Catalogue	`test-editor.page.ts` `createAll()` navigates away, `updateAll()` reloads	FG-4
B-05	S2	After browser back/forward between two service or test editors, the page shows and acts on the previous record (a deactivation hit the wrong service).	Catalogue	editors read the record id once from the route snapshot	FG-5

5.2 Severity 3

ID	FINDING	MODULE	GROUP
B-07	The treasury picker on treasury access is kept across sign-out and sign-in; a reactivated treasury is not offered.	Treasury	FG-2
B-06	Role, user and contract-tier actions answered with 204 are shown as failures.	Organization, Pricing	FG-3
A-08	Pages outside a user's rights, and Release-2 billing routes, open by typed URL; the server refuses the data.	Shell routes	FG-6
C-14	A platform session can open the `/account` pages (no tenant guard on that route).	Shell routes	FG-6
C-15	`/admin` pages have no permission guard; hidden pages open by URL (server answers 403).	Shell routes	FG-6

ID	FINDING	MODULE	GROUP
A-02	Reception (view-only on results) is offered the comment and internal-note dialogs; the server refuses the save.	Results	FG-7
A-03	The patient Documents tab is shown to users without `files.view` and fails with 403.	Patients	FG-7
A-04	The treasuries list shows a raw branch id to users without `organization.view`.	Treasury	FG-7
C-04	Catalogue CSV export ignores the search and status filters.	Catalogue	FG-8
B-10	Branches, roles, users, payers and treasuries have no export (SRS grid rule).	Organization, Pricing, Treasury	FG-8
B-02	A branch was saved with a governorate of another country; the server does not check the pair.	Organization	FG-9
C-03	Add client does not check mobile numbers against the country length in the browser; the server message names no field.	Platform	FG-9
C-07	Add and edit client offer inactive plans, which the server refuses.	Platform	FG-9
C-08	A country's time zone is not checked against IANA names (`Mars/Base` was saved).	Platform	FG-9
A-05	Payments prints a receipt after every payment although the laboratory's auto-print parameter is off (the cashier cannot read the settings, and the page defaults to printing).	Billing	FG-11
A-06	The payment and refund form keeps note, reason, method and reference after a save; a refund was stored with the previous note.	Billing	FG-11
C-09	The laboratory settings answer shows the code default instead of the inherited platform value.	Settings	FG-12
C-17	Client creation is not in the platform audit trail (filed in the new laboratory's trail).	Platform, Audit	FG-12
C-18	The audit log has no Client column (SA-09).	Audit	FG-12
D-01	Append-only triggers on the audit tables, payments and refunds cover UPDATE and DELETE but not TRUNCATE; only the owner role could truncate (the runtime role cannot).	Database	FG-13
A-09	The patients list lacks the visit-count and last-visit columns of CP-11.	Patients	FG-14

5.3 Severity 4

ID	FINDING	GROUP
B-08, B-13	An inactive sample condition is offered in the test editor; the formula error repeats its position.	FG-4
B-12	Read-only users can type into the service-sequence and test-editor fields (there is no Save).	FG-7
B-09, A-15	CSV exports ignore the status filter and use inconsistent formats; registration dates are raw UTC.	FG-8
B-03, C-06, C-19	Generic or raw untranslated validation messages; a wallet top-up of 250.555 is silently rounded.	FG-9
A-07, C-10, C-11, C-12, C-16, A-10, A-12	Raw dictionary keys shown briefly; ten English hints on the Arabic parameters page; Release-2 features listed on the landing page; two menu entries both called "Dashboard"; English branch name under the Arabic letterhead; dashboard captions and mixed digits.	FG-10
A-11, A-13, A-14, B-01, B-11, B-14	Gender-refused service shown as "Not priced yet" in price query; the F2 picker empty until a term is typed; worklist search ignores patient names; new branch currency not defaulted to EGP; lock message and the sign-in return address after sign-out; an unsaved role choice dropped when saving branches.	FG-14

6. Recommended fix plan

GROUP	CONTENT	DEFECTS	APPROACH	EFFORT
FG-1	Session identity on refresh	C-01 (S1)	after every refresh compare user and tenant with the current ones; on a change clear the state and send the tab to sign-in; tell other tabs of a sign-out (BroadcastChannel)	1–2 days
FG-2	Per-user state after sign-out	A-01 (S1), C-13 (S2), B-07 (S3)	full page reload on sign-out and on a user change, which discards every module's in-memory state at once; keep the per-facade refresh for visits within one session	1 day
FG-3	Successful empty answers	C-02 (S2), B-06 (S3)	one shared helper for 204 answers in every API service (organization, pricing, results, patients, samples, integration, auth store), with a spec	1 day
FG-4	Test editor	C-05/B-04 (S2), B-08, B-13 (S4)	keep typed bands and values on a refused step, show the server reason per section; filter inactive conditions; message text	2 days

GROUP	CONTENT	DEFECTS	APPROACH	EFFORT
FG-5	Editors bound to the route	B-05 (S2)	read the record id from the route as a signal and reload on change	1 day
FG-6	Route guards	A-08, C-14, C-15 (S3)	permission guard derived from the navigation registry on every route; tenant guard on `/account`; release guard on Release-2 routes	1–2 days
FG-7	Rights-aware affordances	A-02, A-03, A-04 (S3), B-12 (S4)	hide or disable actions and tabs the user cannot use	1 day
FG-8	Exports	C-04, B-10 (S3), B-09, A-15 (S4)	export the filtered set; add the missing exports; one CSV format (local dates, Yes/No, labels)	2 days
FG-9	Validation and messages	B-02, C-03, C-07, C-08 (S3), B-03, C-06, C-19 (S4)	server checks (governorate in country, IANA zone, active plan) and field-level messages in both languages	2 days
FG-10	Dictionaries and wording	A-07, A-10, A-12, C-10, C-11, C-12, C-16 (S4)	missing keys, Arabic hints, landing text, letterhead, labels	1 day
FG-11	Billing form and printing	A-05, A-06 (S3)	read the auto-print parameters through a billing-scoped endpoint; reset the form after each save	1 day
FG-12	Platform audit and settings	C-09, C-17, C-18 (S3)	show the inherited value; file onboarding in the platform trail (decision A-10 of LIS-RP-001); client column	2 days
FG-13	Database hardening	D-01 (S3)	add statement-level TRUNCATE triggers to the append-only tables in a new migration, with an architecture gate	half a day
FG-14	Small UX items	A-09 (S3), A-11, A-13, A-14, B-01, B-11, B-14 (S4)	individual fixes	2 days

Suggested order: FG-1 and FG-2 first (the two S1), then FG-3, FG-4, FG-5 (the S2), a targeted re-test of those cases, then FG-6 to FG-14 alongside user acceptance.

7. Not tested or blocked, and why

ITEM	REASON	COVERAGE ELSEWHERE
Password recovery completion, subscription wizard completion, inactive-template fallback text	no SMS / e-mail gateway on this host (pilot prerequisite B-01 of LIS-RP-001)	both flows tested up to the one-time-code step

ITEM	REASON	COVERAGE ELSEWHERE
Laboratory block on the profile page	the demo laboratory has no subscription record	—
Paging of lists	no list reached the smallest page size of 20 in the test data	paging is covered by the frontend unit tests
Sessions CSV export, report-template logo upload, test timing tab in the Super Admin editor	not reached in the time box	numeric, list, formula and text tests validated in the client editor (B)
Forced API requests from the browser	no access token is placed in a page by policy	validation, 403, 404, 409 and isolation covered by the backend-cycle script (D)
Native printing and file downloads	automation does not open the print dialog	rendered documents and downloaded files captured in the page and checked
Results query submitted with Enter	synthetic key events do not submit the form (inconclusive)	F8 tested and working

8. Test data and housekeeping

- All validation data carries the prefix **V11**: three "V11 API Lab" clients (one per backend-cycle run), "V11 Validation Lab", the Walk-through Laboratory set-up (branches, roles, users, catalogue, prices, treasuries) and its proof visit, and visits, payments and refunds in the demo laboratory. The full list is in each result file.
- New accounts and their passwords are recorded only in the git-ignored credentials file on this host (`v11.*` , `v11api.*` , `v11lab.admin`).
- The auto-print parameters of the demo laboratory and the Walk-through Laboratory are off for automation; switch them back on before a manual session. Platform parameters were restored.
- The installed site stayed online during the whole validation; the testers used a separate stack on port 5102 against the same database.

9. Detailed results

FILE	CONTENT
`docs/validation/2026-10-11/client-operations.md`	tester A: coverage, 133 cases, 13 database verifications, 15 defects

FILE	CONTENT
`docs/validation/2026-10-11/client-setup.md`	tester B: coverage, 197 cases, 20 database verifications, 14 defects
`docs/validation/2026-10-11/super-admin-and-public.md`	tester C: coverage, 139 cases, 23 database verifications, 19 defects
`docs/validation/2026-10-11/backend-cycle.md` and `tests/validation/backend-cycle.mjs`	tester D: the repeatable script, 36 steps, 320 assertions, negative checks, deployed run, 1 defect; rerun with `node tests/validation/backend-cycle.mjs http://127.0.0.1:5102`

LIS-VR-001 v1.0 · 2026-10-11 · Sky LIS, National Technology · Validation of release v0.3.8. Defect ids are stable and match the detailed result files.